

KEY MANAGEMENT GOVERNANCE

For Ethereum node operations using Prysm, HashiCorp Vault, and AWS KMS

Purpose	A decision-ready governance baseline that translates NIST SP 800-131A Rev. 2 and SP 800-57 Parts 1 and 2 into operating requirements for a blockchain node operator.
Scope	Production and disaster-recovery environments that operate Prysm beacon/validator services, supporting AWS accounts, Vault, CI/CD, logging, backups, and personnel access.
Status	Draft for adoption. This is an organizational policy baseline, not a claim of NIST or FIPS compliance.

Management statement

Validator signing keys are safety-critical assets: their misuse can create irreversible network penalties, including slashing. This policy therefore separates custody, deployment, approval, and recovery duties; treats access to signing keys as production change; and uses managed cryptographic services to minimize exportable key material.

Document control

Field	Value
Owner	Security and Infrastructure leadership
Review cadence	At least annually, after a material protocol/client change, or after any key-management incident
Approval	Executive owner plus Security owner
Effective date	On approval
Classification	Internal

Assumptions and boundary

This draft assumes an Ethereum proof-of-stake validator operation using an Offchain Labs-maintained Prysm distribution. Exact topology, custody model, legal obligations, and whether the company runs validators, beacon nodes only, or both were not provided. Requirements marked "validator" apply only where the company controls validator signing credentials. The network protocol dictates BLS signing behavior; NIST algorithm-transition guidance governs the company-controlled cryptography around it (storage, transport, wrapping, access, and administration).

1. Policy index and source index

The following index is intended to make evidence collection and future policy updates tractable. The final NIST publications are the normative sources for this document; drafts are tracked only as watch items.

NIST source / location	What it contributes	Company use
SP 800-57 Part 1 Rev. 5: Sections 5-8; 9-10; Appendix A	Key roles, keying-material protection, lifecycle functions, inventory, cryptoperiod concepts, security-strength tables.	Asset inventory, access control, lifecycle records, compromise response, encryption and signing baselines.
SP 800-57 Part 2 Rev. 1: Sections 2-4; Appendices A-C	Key Management Policy (KMP), Key Management Practice Statement (KMPS), documentation and planning expectations.	Policy authority, named roles, operating procedures, exception process, evidence pack.
SP 800-131A Rev. 2: Sections 1-4; Tables 1-9	Status of algorithms and key lengths; transition planning.	Prohibit legacy cryptography in company-controlled services and maintain migration inventory.
SP 800-57 Part 3 Rev. 1: Sections 5-7	Application-specific operational guidance.	Reference for TLS, PKI, and infrastructure implementation decisions.
Watch list: SP 800-57 Rev. 6 IPD and SP 800-131A Rev. 3 IPD	Potential successor guidance; not authoritative until final.	Security team reviews changes quarterly and opens a policy-change ticket where needed.

2. Governance requirements

- The company SHALL maintain a KMP approved by the executive security owner and a KMPS owned by Infrastructure. The KMPS SHALL identify systems, roles, procedures, records, and tool configurations that implement this policy.
- The company SHALL classify all private keys, Vault recovery material, AWS KMS authorization paths, validator keystores, TLS private keys, and encrypted backups as sensitive keying material or key-management metadata.
- Each key SHALL have an accountable owner, defined purpose, environment, algorithm/format, creation date, cryptoperiod or review trigger, storage location, permitted users, backup/recovery method, and destruction or retirement status.
- No individual may both approve a production validator-key recovery/import and execute it. Security and Operations approvals SHALL be separate for these actions.
- Exceptions require a documented risk acceptance, compensating controls, named expiry date, and Security owner approval.

3. Key inventory and handling model

Inventory records must distinguish protocol keys from keys the company can select or rotate. A validator key cannot be rotated like a TLS certificate without a planned validator migration; custody and authorization controls are therefore primary safeguards.

Asset class	Examples	Control objective	Required authority
Validator signing key (validator only)	EIP-2335 keystore / BLS signing credential	Prevent export, duplicate use, unauthorized signing, and unsafe recovery.	Dual approval for import/recovery; named validator owner.
AWS KMS customer managed key	Vault auto-unseal, backup encryption, application envelope encryption	Protect root/envelope keys; separate KMS administration from data/key use.	KMS key administrator and KMS key user roles are distinct.
Vault secrets and recovery material	Keystore passphrases, service credentials, recovery shares	Constrain read paths, provide audited break-glass, retain no plaintext in pipelines.	Vault policy owner; custodian roster.
TLS / API / SSH credentials	RPC ingress, monitoring, CI/CD, administration	Protect node control plane and authenticated service channels.	System owner; automated renewal where practical.
Backups and audit records	Encrypted keystore backup, slashing-protection database backup	Restore only under tested, authorized procedures; retain immutable evidence.	Backup owner and incident commander.

Control-plane design rules

- Use AWS KMS customer managed keys with key policies that explicitly limit administrative actions and cryptographic use to separate IAM roles. Enable CloudTrail management and data-event logging where applicable, route logs to a protected account, and alert on disablement, deletion scheduling, policy change, grants, and decrypt activity outside approved identities.
- Vault SHALL use an approved seal and be configured with TLS, audit devices, least-privilege policies, short-lived authentication, and a separate break-glass path. Store references, not plaintext secrets, in CI/CD. Never place validator keystores, keystore passwords, Vault tokens, or recovery shares in Git, container images, chat, or ticket attachments.
- Prysm validator signing SHALL run on a dedicated, hardened workload identity. Limit egress and management access; bind its Vault and AWS permissions only to the required paths and key operations. Do not share a validator key across concurrently active validator clients unless an approved high-availability/safety design proves mutually exclusive signing.
- Slashing-protection data is a safety asset. Back it up with its matching validator state, validate restores in a non-production drill, and require explicit approval before moving a validator key to another signer/client.

4. Mandatory lifecycle requirements

Lifecycle phase	Requirement	Evidence
Plan / request	Record purpose, system, owner, classification, dependencies, recovery approach, and approval before creation or import.	Approved request; inventory record.
Generate / import	Generate company-controlled keys in approved services or import only through a documented ceremony. Verify source, integrity, and no duplicate active signer. Validator keys require slashing-protection review.	Ceremony log; checksum/attestation where applicable; dual approvals.
Distribute / activate	Use authenticated, encrypted channels. Never transmit private key material by email, chat, or source control. Validate recipient identity and least privilege before enabling use.	Deployment record; Vault audit; IAM evidence.
Use / monitor	Permit only declared operations. Continuously log and alert on privileged Vault/KMS actions, authentication failures, policy changes, and signer availability/safety alerts.	Centralized audit logs; alert test results.
Backup / recover	Maintain encrypted backups and test recovery at least annually. Recovery material access requires break-glass controls and dual authorization.	Restore-drill report; access record.
Suspend / retire / destroy	Disable use rapidly on suspected compromise or role change. Retain enough evidence for investigation. Destroy only after dependency and retention checks; AWS KMS deletion schedule is a controlled change.	Incident/change record; inventory status; deletion approval.

Cryptoperiod and rotation interpretation

SP 800-57 treats cryptoperiod decisions as risk-based. This company SHALL assign a review period to every key. For infrastructure secrets and service credentials, rotate on a defined schedule and immediately after suspected exposure. For customer managed KMS keys, enable rotation where compatible with the application and record the decision. For validator signing keys, do not rotate merely on a timer; use a documented validator exit/migration process and verify slashing protection before any new signer becomes active. KMS key rotation does not rotate encrypted application data automatically; the KMPS must define re-encryption/backfill responsibility.

5. Approved cryptography baseline

This baseline applies to company-controlled cryptography, not to immutable Ethereum protocol choices. Security may approve a documented exception where vendor or protocol compatibility makes a listed choice impossible.

Use	Required baseline	Prohibited / transition action
Data at rest	AES-128 or AES-256 using an approved authenticated mode/service; AWS KMS envelope encryption for application-managed data.	Do not introduce TDEA/3DES. Inventory and replace legacy encryption.
Hash / integrity	SHA-256, SHA-384, SHA-512, SHA-3 family, or an approved service construction.	Do not select SHA-1 for new security functions; remove it from certificates/signatures and review legacy verification dependencies.
TLS and certificates	TLS 1.2 or later (prefer TLS 1.3); certificates and signature schemes meeting current platform/NIST policy.	Disable SSL, TLS 1.0/1.1, weak ciphers, and weak certificate chains.
Public-key cryptography	Use security strength of at least 112 bits for new company-controlled uses; follow NIST transition tables for algorithm-specific minimums.	Avoid new RSA keys below 2048 bits; do not use deprecated 1024-bit RSA for protection.
Randomness	Use OS/CSP approved cryptographic RNGs and managed-service generation.	No application-built PRNG or predictable seed for key creation.

6. Access, operations, and incident response

Privileged access

- Require phishing-resistant MFA for human access to AWS, Vault, CI/CD, and production administration. Use named identities; prohibit shared administrator accounts except formally controlled break-glass identities.
- Use just-in-time, time-bounded elevation for KMS administrators, Vault policy administrators, and production node access. Review memberships and grants at least quarterly and immediately after role changes.
- Separate production, staging, and development AWS accounts, Vault namespaces/mounts, credentials, and KMS keys. Non-production SHALL not receive production signing key material or production recovery secrets.

Suspected key compromise

On suspected loss, exposure, unauthorized access, duplicate validator signing, or unexpected KMS/Vault action, the incident commander SHALL: (1) preserve logs and relevant configuration snapshots; (2) restrict or suspend affected access; (3) assess validator safety before restarting or relocating any signer; (4) revoke/rotate company-controlled credentials and update policies; (5) notify decision owners and legal/compliance as applicable; and (6) complete a post-incident review with inventory and KMPS updates. Never use an incident as a reason to blindly restart multiple validator clients with the same key.

Minimum evidence pack

Control area	Evidence to retain	Cadence
Inventory	Export of key register and ownership/review status	Monthly
Access	Vault policies/audit records; AWS IAM/KMS policies, grants, and access reviews	Quarterly
Operations	Change records for validator key import/migration, KMS policy changes, Vault configuration	Per event
Resilience	Encrypted-backup verification and validator/slashing-protection recovery drill	At least annually
Cryptographic transition	Algorithm and certificate inventory; exception register; deprecation remediation plan	Quarterly
Assurance	Control-owner attestation and sampled evidence review	Annually

7. Implementation roadmap

Priority	First actions	Success criterion
0-30 days	Build inventory; identify every validator key and current signer; enable/verify Vault audit logging and AWS CloudTrail; eliminate plaintext secrets in repositories and pipelines.	100% known key owners and locations; no critical plaintext exposure.
31-60 days	Publish KMPS runbooks for onboarding, backup/restore, compromise, and Prysm signer migration; implement dual approval and alerting.	Tabletop exercise and a non-production restore drill pass.
61-90 days	Perform cryptographic inventory; remediate legacy TLS/certificates; complete least-privilege review of AWS KMS and Vault policies; test break-glass.	Risk register has owners/dates; sampled evidence supports control operation.
Ongoing	Review NIST drafts/finals, client-release changes, and protocol changes; test recovery and access reviews.	Annual policy approval and tracked improvements.

Appendix A. Requirements crosswalk

ID	Company requirement	Primary NIST anchor
KMG-01	Maintain approved KMP and KMPS with named authority, scope, roles, exception and review process.	SP 800-57 Pt. 2 Rev. 1, Sections 3-4
KMG-02	Maintain complete inventory and protect both key material and key-management metadata.	SP 800-57 Pt. 1 Rev. 5, Sections 6-7; Appendix A
KMG-03	Apply lifecycle controls: generation, distribution, storage, use, backup, recovery, destruction.	SP 800-57 Pt. 1 Rev. 5, Sections 7-8
KMG-04	Use role separation, least privilege, authenticated access, audit, and periodic review.	SP 800-57 Pt. 1 Rev. 5, Sections 5-7; SP 800-57 Pt. 2 Rev. 1, Section 4
KMG-05	Use approved strengths/algorithms and maintain a transition inventory and retirement plan.	SP 800-131A Rev. 2, Sections 3-4 and tables; SP 800-57 Pt. 1 Rev. 5, Appendix A
KMG-06	Establish cryptoperiod/review decisions and controlled key replacement/recovery.	SP 800-57 Pt. 1 Rev. 5, Sections 5, 7-8
KMG-07	Test continuity and compromise procedures; preserve evidence and update policy after events.	SP 800-57 Pt. 1 Rev. 5, Sections 8-9; SP 800-57 Pt. 2 Rev. 1, Section 4

Appendix B. References

NIST SP 800-131A Rev. 2, *Transitioning the Use of Cryptographic Algorithms and Key Lengths*, March 2019. <https://doi.org/10.6028/NIST.SP.800-131Ar2>

NIST SP 800-57 Part 1 Rev. 5, *Recommendation for Key Management: Part 1 - General*, May 2020. <https://doi.org/10.6028/NIST.SP.800-57pt1r5>

NIST SP 800-57 Part 2 Rev. 1, *Recommendation for Key Management: Part 2 - Best Practices for Key Management Organizations*, May 2019. <https://doi.org/10.6028/NIST.SP.800-57pt2r1>

NIST SP 800-57 Part 3 Rev. 1, *Recommendation for Key Management: Part 3 - Application-Specific Key Management Guidance*, January 2015. <https://doi.org/10.6028/NIST.SP.800-57pt3r1>

NIST CSRC Key Management publications index, accessed 2026-08-30. <https://csrc.nist.gov/Projects/key-management/publications>

Interpretation note

NIST SP 800-57 Part 2 is written for U.S. Government agencies. This document uses its policy and practice structure as a strong governance pattern for a private-sector operator; it does not assert that the company is a federal agency or that NIST documents alone satisfy regulatory, contractual, custody, or protocol obligations. Obtain legal, audit, and protocol-specific review before adopting this as a binding policy.